

Auditoría de Seguridad

VR Training AI Server v3.2.0

Tipo: Auditoría de Seguridad y Plan de Mejora

Versión del Sistema: 3.2.0

Fecha: 16 de Enero, 2026

Estado: Pre-Producción

Prioridad: ALTA

■■ DOCUMENTO CONFIDENCIAL

Este documento contiene información sensible sobre vulnerabilidades de seguridad.
Distribución restringida al equipo de desarrollo.

Tabla de Contenido

1.	Resumen Ejecutivo	3
2.	Vulnerabilidades Identificadas	4
2.1	Vulnerabilidades Críticas (CVSS 9.0-10.0)	4
2.2	Vulnerabilidades Altas (CVSS 7.0-8.9)	5
2.3	Vulnerabilidades Medias (CVSS 4.0-6.9)	6
3.	Herramientas de Seguridad a Desarrollar	7
3.1	IP Monitoring Dashboard	7
3.2	Security Scanner	8
3.3	Network Sniffer	8
3.4	Access Control Manager	9
3.5	Encryption Manager	9
4.	Plan de Implementación	10
5.	Prioridades y Timeline	11
6.	Métricas de Éxito	12

1. Resumen Ejecutivo

El servidor VR Training AI Server v3.2.0 se encuentra actualmente en estado funcional pero presenta **múltiples vulnerabilidades críticas de seguridad** que deben ser resueltas antes de su despliegue en producción. Esta auditoría identifica 10 vulnerabilidades principales y propone el desarrollo de 5 herramientas especializadas para monitoreo y protección.

Categoría	Cantidad	Prioridad
Vulnerabilidades Críticas	4	Inmediata
Vulnerabilidades Altas	4	Alta
Vulnerabilidades Medias	2	Media
Herramientas a Desarrollar	5	Según fase
Tiempo Estimado de Implementación	3-5 días	—

Conclusión: El sistema requiere hardening de seguridad inmediato. Se recomienda implementar las correcciones en el orden de prioridad establecido, comenzando con autenticación (API Keys), cifrado (HTTPS), y control de acceso (whitelist de IPs).

2. Vulnerabilidades Identificadas

Se han identificado 10 vulnerabilidades principales que comprometen la seguridad del sistema. Están categorizadas según el estándar CVSS (Common Vulnerability Scoring System).

2.1 Vulnerabilidades Críticas (CVSS 9.0-10.0)

ID	Vulnerabilidad	CVSS	Impacto
V-01	Sin autenticación en endpoints	10.0	Acceso no autorizado total
V-02	HTTP sin cifrado	9.5	Interceptación de datos sensibles
V-03	Sin validación de input	9.2	Ataques de inyección
V-04	ChromaDB sin cifrar en disco	9.0	Extracción de manuales completos

V-01: Sin Autenticación

- **Descripción:** Todos los endpoints (/query, /index, /query_audio) son accesibles sin credenciales.
- **Riesgo:** Cualquier dispositivo en la red WiFi puede ejecutar queries, indexar PDFs, o extraer información.
- **Solución:** Implementar sistema de API Keys con header Authorization: Bearer.

V-02: HTTP Sin Cifrado

- **Descripción:** Todo el tráfico viaja en plain text (HTTP).
- **Riesgo:** Queries y respuestas visibles con Wireshark. Man-in-the-middle posible.
- **Solución:** Implementar HTTPS con certificado TLS (autofirmado para red local).

2.2 Vulnerabilidades Altas (CVSS 7.0-8.9)

ID	Vulnerabilidad	CVSS	Impacto
V-05	Sin rate limiting	8.5	Ataques de denegación de servicio
V-06	Error messages detallados	7.8	Information disclosure de paths
V-07	Sin logging de seguridad	7.5	Ataques pasan desapercibidos
V-08	Firewall muy permisivo	7.2	Acceso desde cualquier IP local

2.3 Vulnerabilidades Medias (CVSS 4.0-6.9)

ID	Vulnerabilidad	CVSS	Impacto
V-09	Sin monitoreo de accesos	6.5	Sin visibilidad de actividad

V-10	Sin rotación de logs	5.2	Logs pueden llenarse o perderse
------	----------------------	-----	---------------------------------

3. Herramientas de Seguridad a Desarrollar

Se propone el desarrollo de 5 herramientas especializadas para monitoreo, detección, y gestión de seguridad del sistema. Cada herramienta aborda aspectos específicos de la arquitectura de seguridad.

3.1 IP Monitoring Dashboard

Propósito: Visualizar en tiempo real qué dispositivos están conectados al servidor.

Funcionalidades:

- Lista de IPs conectadas actualmente con timestamp de última actividad
- Historial de accesos por IP (últimos 7 días)
- Geolocalización básica (detectar IPs fuera de rango local)
- Estadísticas de uso: requests/hora por cliente, endpoints más usados
- Alertas visuales para IPs no reconocidas

Tecnología: Flask + HTML/CSS/JS dashboard, SQLite para historial

Tiempo estimado: 4-6 horas

3.2 Security Scanner

Propósito: Auditoría automática de configuración y detección de vulnerabilidades.

Funcionalidades:

- Verificar que firewall de Windows tiene reglas correctas
- Escanear puertos abiertos en el sistema (detección de servicios inseguros)
- Verificar permisos de archivos críticos (ChromaDB, logs, configuraciones)
- Chequear versiones de librerías contra CVE database
- Generar reporte PDF con hallazgos y recomendaciones

Tecnología: Python + nmap/psutil + reportlab para PDFs

Tiempo estimado: 6-8 horas

3.3 Network Sniffer

Propósito: Capturar y analizar tráfico del puerto 5000 para detectar anomalías.

Funcionalidades:

- Captura de paquetes TCP en puerto 5000 en tiempo real
- Detección de patrones sospechosos (SQL injection, path traversal, XSS)
- Alertas ante queries anómalas (longitud excesiva, caracteres especiales)
- Log detallado de intentos de ataque con evidencia
- Modo de análisis forense: guardar capturas PCAP para revisión

Tecnología: Python + scapy o tshark

Tiempo estimado: 5-7 horas

3.4 Access Control Manager

Propósito: Gestión centralizada de autenticación y autorización.

Funcionalidades:

- Generar API keys únicos por dispositivo Quest 3
- Revocar keys comprometidos o perdidos
- Gestionar whitelist de IPs permitidas (agregar, eliminar, actualizar)
- Configurar rate limits personalizados por cliente
- Ver log de intentos de acceso bloqueados con detalle

Tecnología: Python + SQLite/JSON para storage, GUI con tkinter

Tiempo estimado: 4-6 horas

3.5 Encryption Manager

Propósito: Gestión de cifrado de datos en reposo y certificados TLS.

Funcionalidades:

- Cifrar/descifrar directorio de ChromaDB con AES-256
- Generar certificados TLS autofirmados para HTTPS
- Gestionar claves de cifrado seguramente (no en plaintext)
- Verificar integridad de archivos cifrados (checksums)
- Backup automático cifrado de base de datos

Tecnología: Python + cryptography library + OpenSSL

Tiempo estimado: 5-7 horas

4. Plan de Implementación

El plan de implementación se divide en 4 fases secuenciales, priorizando las vulnerabilidades críticas y las herramientas esenciales.

Fase	Objetivo	Acciones	Duración
Fase 1 CRÍTICO	Autenticación y Cifrado	• Implementar API Keys • Activar HTTPS/TLS • Configurar whitelist IPs • Rate limiting básico	Día 1-2 (8-12 hrs)
Fase 2 VALIDACIÓN	Input Validation y Logging	• Sanitización de queries • Validación de archivos • Logger de accesos • Error handling seguro	Día 2-3 (6-8 hrs)
Fase 3 CIFRADO	Datos en Reposo	• Cifrar ChromaDB • Firewall automation • Permisos de archivos • Backup cifrado	Día 3-4 (6-8 hrs)
Fase 4 MONITOREO	Herramientas	• IP Monitor Dashboard • Security Scanner • Access Control Manager • Testing completo	Día 4-5 (8-10 hrs)

Nota importante: Cada fase debe completarse y testearse antes de continuar con la siguiente. Se recomienda hacer backup completo antes de cada fase.

5. Prioridades y Timeline

Prioridad	Item	Impacto	Esfuerzo
1	API Keys	Crítico	2 hrs
2	HTTPS/TLS	Crítico	3 hrs
3	Whitelist IPs	Alto	1 hr
4	Rate Limiting	Alto	2 hrs
5	Input Validation	Crítico	3 hrs
6	Logger de Accesos	Alto	2 hrs
7	Cifrado ChromaDB	Crítico	4 hrs
8	IP Monitor	Medio	5 hrs
9	Security Scanner	Medio	7 hrs
10	Access Control Manager	Medio	5 hrs

Timeline Detallado:

Día 1 (Lunes): Implementar API Keys, configurar HTTPS, setup whitelist (7 hrs)

Día 2 (Martes): Rate limiting, input validation, logger (7 hrs)

Día 3 (Miércoles): Cifrar ChromaDB, firewall automation (6 hrs)

Día 4 (Jueves): Desarrollar IP Monitor y Security Scanner (8 hrs)

Día 5 (Viernes): Access Control Manager, testing final, documentación (6 hrs)

Total estimado: 34 horas de trabajo distribuidas en 5 días.

6. Métricas de Éxito

Al completar la implementación, el sistema debe cumplir con los siguientes criterios de éxito:

Métrica	Objetivo	Método de Verificación
Autenticación	100% requests requieren API key válida	Intentar acceso sin key → rechazo 403
Cifrado	100% tráfico cifrado (HTTPS)	Captura con Wireshark → no texto plano
Control de Acceso	0 accesos desde IPs no autorizadas	Intentar desde IP externa → bloqueo
Rate Limiting	Máx. 10 requests/min respetado	Enviar 20 requests → 10 exitosos, 10 bloqueados
Logging	100% accesos registrados	Verificar log contiene todos los requests
Cifrado BD	ChromaDB no legible sin clave	Intentar abrir archivos .sqlite → cifrados
Performance	Latencia adicional < 10%	Medir tiempo de respuesta antes/después
Monitoreo	Dashboard funcional en tiempo real	Ver IPs conectadas y estadísticas

Conclusión Final:

La implementación completa de las medidas de seguridad propuestas elevará el nivel de protección del VR Training AI Server de **vulnerable** a **seguro para producción**. El sistema estará protegido contra las amenazas más comunes y contará con herramientas de monitoreo para detectar y responder a incidentes de seguridad.

Se recomienda realizar pentesting una vez completada la implementación para validar la efectividad de las medidas adoptadas.

Security Team
VR Training AI Server Project
Enero 2026